

7.15 master audit: retrospective and close-out

Date: 2026-09-29. Author: Claude (Sonnet 5.5), from the master ledger (docs/release/MASTER-AUDIT-TEMPLATE.md), the SOP (docs/release/REHEARSAL-SOP.md), the fork's PR and review history, and measurements taken on 2026-09-29. Sources are named per section; nothing here is recalled from memory alone.

1. Summary

All thirteen audit blocks (plus 00a and 00b) are audited to their owner-directed checkpoints. The chain that contains Blocks 4, 5 and 7 through 13 has a tip (Block 13) that is green in hosted CI with verified artifacts; Blocks 11 to 13 were re-verified this week. **The audit is not yet release-ready, for one measured reason (section 4): the accepted heads of Blocks 00a, 00b, 01, 02, 03 and 06 were audited on their own lineages and were never assembled into the chain that Blocks 8 to 13 were built on.** The ledger already recorded "predecessor integration pending" for several of them. This retro measures that gap and proposes how to close it. Nothing has been merged, no upstream PR exists, and no device has been flashed.

2. How long it took

Measure	Start	End	Length
The 7.15 program (release PR #226, "Release 7.15.0")	2026-04-30	2026-09-29	152 days, 21.7 weeks
The audit series (first audit PR #683, P01/P02 requalification)	2026-09-08	2026-09-29	21 days, 3.0 weeks
The master audit blocks (00a complete 2026-09-22)	2026-09-22	2026-09-29	8 days, about 1 week

The multi-chain work that 7.15 builds on began earlier (7.14 multi-chain PRs on 2026-03-24 and 2026-03-26). The short answer to "how many weeks": **about 22 weeks for 7.15, of which the audit itself was 3 weeks, and the block-by-block master audit was about one week.**

3. Scale

Measure	Value	Source
Pull requests opened from #683 to #890	199	GitHub, all states
Copilot reviews, across 48 of those PRs	122	GitHub reviews API
Review threads on those PRs	314	GitHub GraphQL
Candidate change over develop at Block 13	305 non-merge commits, 432 files, +69,210 / -3,730 lines	git diff develop..HEAD
Hosted CI at the Block 13 head	1,645 pass, 73 declared skips, 0 fail; firmware 773 full / 197 Bitcoin-only; both ARM variants build	Run 36619349842 artifacts (verified); docs-only head run 36622461353 green

Measure	Value	Source
Fork release candidates before the audit	release/7.15.0-rc1 through rc27 (not every number exists)	fork branch list

4. The assembly gap (the main finding)

Ancestry check against the Block 13 head (603fb904f), then a content check: for each block, the share of its added non-doc lines that still exist in the same file at the Block 13 head. Blocks that are in the lineage calibrate what "present" looks like.

Block	PR, head	In Block 13 ancestry	Added lines present
04	#834 f05bfe96d	yes	100.0%
05	#858 5c3f2d927	yes	96.4%
08	#872 db7c711a6	yes	99.7%
09	#875 ad7a3fe0d	yes	99.3%
00a	#844 9cb72384f	no	87.1% (3 files absent)
00b	#856 8126f802f	no	80.9% (7 files absent)
01	#831 752466b25	no	75.2%
02 (P02)	#855 9237d0a30	no	38.2% (4 files absent)
03 (P03)	#833 5aa047e4d	no	55.9% (1 file absent)
06	#859 9a177aa21	no	93.1%

Absent files include `usb_rx_callbacks.h`, `test_p02_transport.py`, `test_p03_recovery.py`, `otp_entropy.cpp`, `review_handlers.cpp` and `docker-compose.audit.yml`. Some missing lines are legitimately superseded by later rewrites (for example Block 11 replaced the Solana path), so the percentages overstate the loss; but they are not zero, and files that do not exist cannot have been superseded line by line.

Why it happened. Blocks were audited against provisional or unaccepted predecessor heads (the ledger says so: Stack 06 was "based on unaccepted Stack 05"; Stacks 01 and 04 record "predecessor integration pending"). The fixes made under review landed on each block's own PR head, and later blocks were built on the earlier, unrepaired stack commits from 2026-09-20/21. The SOP describes the assembly step (accepted units on an isolated integration candidate, with a receipt); it was scheduled after the blocks and not yet performed.

Assembly forecast (`git merge-tree`, no working tree touched, all merge bases dated 2026-09-21): merging each missing head into the Block 13 tip conflicts in 00a 13 files, 00b 72, 01 8, 02 11, 03 13, and 06 merges clean. The conflicts are in the most security-sensitive files (`ethereum.c`, `fsm.c`, `storage.c`, `reset.c`, `messages.c`, `keepkey_flash.c`, `keepkey_main.c`, CI and report gates), so they need judgment, not a script. Details: `715-assembly-forecast-20260929.json`.

5. Block ledger

Block	PR(s)	Final head	State as recorded
00a	#844	9cb72384f	Complete 2026-09-22; two Copilot reviews, Findings: None

Block	PR(s)	Final head	State as recorded
00b	#856	8126f802f	Complete 2026-09-25 after nine Copilot reviews, the last Findings: None
01	#831	752466b25	Source audit done 2026-09-23 after four authorized reviews (19 issues in the first three); predecessor integration pending
02 (P02)	#855	9237d0a30	Complete by explicit owner acceptance 2026-09-23
03 (P03)	#833	5aa047e4d	Complete by owner direction 2026-09-23
04	#834	f05bfe96d	Complete by explicit owner acceptance 2026-09-23; predecessor integration pending
05	#858	5c3f2d927	Local audit and review checkpoint complete 2026-09-24
06	#859	9a177aa21	Passed after fourth-review repairs
07	#871 (combined 7b), #837	248397752, 8c654bcd8	Split into 7b1 to 7b3, then recombined by owner direction and continued into Stack 08
08	#872, #873, #874	db7c711a6, 5f4442d8f	Done, owner accepted completion
09	#875	ad7a3fe0d	Completed; the base for Block 10
10	#876	3a6f1cc24	Final readiness 2026-09-28; two of three requests used, round 2 Findings: None
11	#877 plus ten units #879 to #888	62c6150f5	Split after four reviews into 11p, 11a to 11i; every unit green, artifacts verified, no open threads
12	#889	41c7cd7f0	Round 1 passed (nit-class findings); CI green, artifacts verified

Block	PR(s)	Final head	State as recorded
13	#890	603fb904f	Round 1 passed (one documentation nit); CI green, artifacts verified

6. What worked

- **Independent read-only audits before paid review.** They found real defects that Copilot had not: the Block 11f PIN-cancel path that left an identity fingerprint on the stack, Block 12's unwired Pallas checker, a duplicate-identity hole in the report gate, and Block 13's merge interaction risk (which came back clean, with a control to prove it).
- **A failing control for every claim.** Ten mutation or reverting controls were run this week (OTP recovery, lock clearing, wipe observability, Hive serializer roles, the report gate, the Pallas checker, the merged storage guard, the Osmosis cap). Each one either proved a test detects the defect or exposed a vacuous test, notably the OTP probe that modelled a write as a copy.
- **Artifact verification against the exact head**, not "CI is green": head, run and pin identity, PDF and JUnit hashes, per-variant native identities and ARM manifests.
- **The severity rule (2026-09-29).** Nit-only rounds pass; only serious or moderate findings count. It was written to stop the pattern that produced nine reviews on Block 00b and four on Stack 01; it has been applied to Blocks 11 to 13 and has not yet been tested on a full block.
- **Bundles as durable handoffs.** Block 13's isolated clone was gone, and its work came back intact from a verified Git bundle.

7. What did not work, and the cause

Problem	Cause	Evidence	Change
Assembly gap (section 4)	Blocks audited against provisional predecessors; assembly deferred	Presence table, forecast	Perform assembly as its own audited unit before any merge
Review loops on nits	Copilot findings treated as pass/fail regardless of consequence	00b: nine reviews; 122 reviews and 314 threads overall	Severity rule in the SOP
Tests that pass without proving anything	Fakes that model the wrong physics or observe the wrong thing	OTP probe (write as copy), node-only wipe checks, identical entropy draws, a reader that took ## inside a payload for a header	A failing control before a test is trusted
Gates that do not gate	Wiring never checked	Unreferenced Pallas checker; duplicate identity accepted by a set; earlier "silent skip" and symbol-blind gate classes	Every gate needs a control that makes CI red

Problem	Cause	Evidence	Change
Stale evidence churn	Reports naming their own head; PR counts and run IDs edited by hand	Repeated report refresh cycles in every block	A report states the code head it verified; the PR records the final head
Environment	Local Docker unresponsive all week; zsh does not split unquoted variables; runner flakes	Hosted-only native suites; several silent wrong counts before I caught them	Preflight and verification in scripts, bash only, reruns of failed jobs only
Shared main worktree	The SOP is untracked in the main worktree and was edited there by several agents	The severity edit exists only locally	Commit the SOP and ledger to a tracked branch

8. Decisions taken (with where they are recorded)

- Copilot rounds are self-requested, three per code-bearing block, split after three counted failures (SOP, 2026-09-25).
- Severity decides, not Copilot's label; nit-only rounds pass (SOP points 3 to 6, 2026-09-29).
- Two further attempts per unit without splitting for the final audit round (owner, 2026-09-29).
- Block 11 split into ten bounded units after its fourth review (owner-authorized recursive splits).
- Osmosis send cap lifted for non-native denominations; auto-lock renewal left unchanged and tracked as issue #891; the recovery re-roll is not a defect (Block 13 report).

9. Open items

- Owner acceptance of Blocks 11, 12 and 13, and reconciliation of Block 10's newer documentation head with its receipt.
- **Assembly of the six missing block heads** (section 4), then a release candidate that contains them.
- Issue #891 (auto-lock renewal by valid starts) and the non-EVM secret-wipe class (Solana, TON, TRON, Cosmos), not audited line by line.
- Commit the SOP (untracked in the main worktree) with the severity edit, and refresh the hash recorded in the review-budget ledger.
- Physical-device behaviour, OLED readability and power cycles are not claimed by any block.
- Local Docker recovery; cppcheck and the full native suites have been hosted-only.